

SECAUDIT 059 - Skin execution boundary and asset authority

SECURITY AUDIT / PUBLIC REMEDIATION RECORD

Field	Value
Audit ID	2026-09-28-059
Original review date	2026-09-28
Closeout date	2026-10-06
Severity	HIGH architectural authority risk; no confirmed exploitation or confidentiality breach.
Scope	Public skin PHP, manifest-declared templates, skin-packaging paths, shared CSS and JavaScript assets, runtime asset registration, and the routes by which signed skins enter the CMS.
Status	CLOSED WITH FOLLOW-UP. The executable-authority boundary is delivered and fail-closed. Presentation migration integrity was transferred to SECAUDIT 060 and is not represented as having been proved by this audit alone.
Independent review	Claude (Opus 5), 2026-10-05, independently re-ran the authority search and gate analysis. A filename-based gate bypass found during that review was fixed and regression-tested in CMS 0.7.822D.
Related	SECAUDIT 038; SECAUDIT 060; OPAUDIT 020; pre-migration reference v0.7.772D.

1. Summary

SnapSmack skins had accumulated application authority that did not belong in independently packaged presentation code. Before migration, the skin tree contained 254 PHP files; 109 of them touched the database. Skins could also own request inspection, routing decisions, reusable behavior, and direct asset execution. A signed skin therefore carried more authority than its job required.

The remediation moved database access, request interpretation, writes, network calls, validation, and reusable interactions into CMS-owned controllers, repositories, view models, components, and registered assets. Strict schema-v2 skins receive bounded display data and present it. The current skin tree contains 30 PHP templates. The independent closeout search found no skin use of request superglobals, database APIs, filesystem or process authority, dynamic includes, or executable indirection.

The security outcome is closed: a skin cannot regain application authority merely because it is packaged and signed. The migration's presentation outcome is a separate question. That question became SECAUDIT 060 and OPAUDIT 020 after the boundary conversion removed legitimate visible behavior faster than replacement contracts were proved.

2. Findings and dispositions

A. Public skins owned database and request authority (HIGH) - CLOSED

Pre-migration skins mixed presentation with data access and request decisions. That enlarged the trusted computing base and made a skin package capable of changing application behavior rather than only appearance.

The strict runtime now supplies bounded view data. Schema-v2 templates are scanned under a default-deny grammar and rendered through constrained controllers. Current skins contain no database or request authority. Regression gates run during development, skin packaging, Smack Central publication, registry handling, Smackback recovery, and installation.

B. Executable behavior could arrive through skin-owned assets (HIGH) - CLOSED

Direct script tags and unclassified shared assets allowed executable behavior to bypass a central inventory. Shared JavaScript and CSS are now CMS-owned, registered, inventoried, and subjected to explicit security review. The asset inventory records the file, purpose, dependency, and relevant signals. The current heuristic scan reports zero blocking findings. Fourteen remaining direct-engine-tag warnings are legacy registration debt, not hidden authority; they are named and retained under the central asset policy.

C. A filename could bypass the skin scanner (HIGH) - CLOSED IN 0.7.822D

The first implementation skipped any path whose name contained `gitignore`, even when Git did not ignore the file. A declared template such as `notes.gitignore.php` could therefore be packaged, signed, rendered, and omitted from the gate. Independent review reproduced the bypass with forbidden request and process operations.

CMS 0.7.822D removed the filename shortcut. A regression now proves that a manifest-declared `gitignore`-named PHP template is scanned and rejected. The same release wired the presentation ratchet beside the security gate so a future boundary migration cannot silently worsen the recorded parity baseline.

D. Security containment did not prove presentation parity (MEDIUM process) - TRANSFERRED

The original gate strongly proved what skins could no longer do. It did not prove that every legitimate route, setting, component, and interaction still appeared through a bounded replacement. The resulting availability and integrity regressions are documented in SECAUDIT 060 and OPAUDIT 020. Transferring that work is an explicit disposition, not a claim that presentation parity was complete when 059 closed.

3. Verification evidence

- Independent authority search: 30 current skin PHP files, zero forbidden authority hits.
- Asset security inventory: zero blocking findings; every heuristic signal has an explicit disposition.
- Filename-bypass reproduction: successful before the fix and rejected after it.
- Mandatory gate wiring: package builders, Smack Central, registry, installation, recovery, and pre-commit.
- CMS 0.7.822D: filename bypass closed and parity gate made fail-closed.
- CMS 0.7.823D: full regression directory passes; security-policy, gate-wiring, and parity-ratchet regressions pass.
- Current parity ratchet: 43 known strict-route fallthroughs and 611 diagnostic presentation-hook candidates; neither figure is treated as proof of a live failure.

4. Accepted residual items

The following items do not reopen the authority finding:

1. Fourteen direct-engine-tag warnings remain visible in the working scan. They point to CMS-owned assets and are scheduled registration cleanup, not permission for skin-owned executable code.
2. Strict layouts still declare 43 route branches that do not render bounded content. Legacy public entrances currently serve these route families. The mismatch is ratcheted and may only shrink unless the owner records a new decision.
3. The presentation diagnostic reports 611 orphaned CSS-hook candidates. These include genuine omissions, intentional retirements, dynamic classes, and selectors retained for scripts. They require visual classification; they are not 611 confirmed defects.

5. Closure decision

SECAUDIT 059 is closed because the authority it examined has been removed, the gate is mandatory and fail-closed, the independent reviewer reproduced and closed the only discovered bypass, and every residual item has an owner-visible disposition. SECAUDIT 060 remains the authoritative record for the safety and completeness of the migration itself. The project made the correct security decision and initially executed it too mechanically. Closing the authority problem does not erase the visible damage caused by the migration: the boundary stays, and the recovery evidence, mistakes, deferred parity ledger, and human cost stay in the public record too.

Closure boundary

This decision closes the question, "Can a signed presentation package exercise application authority outside its bounded view contract?" It does not close visual acceptance, legacy-route retirement, or the cleanup of reviewed CMS asset tags. Those are separately named work with separate evidence requirements. A later presentation regression does not make the authority conclusion false; a later scanner bypass, package-policy bypass, or return of request/database logic to a skin would reopen it.

Evidence custody

The machine-readable asset inventory and explicit review map remain in the repository. The parity baseline remains executable rather than being copied only into this report. Claude's independent handoff records the reproduced filename bypass, the correction to the first interpretation of route failures, and the exact source checkpoint reviewed. This report therefore does not ask a future reviewer to trust a narrative without the controls and disagreement record that produced it.

Publication statement

Sean approved public closeout on 2026-10-06 after sequential CMS 0.7.822D and 0.7.823D preserved the security fixes and the current 166-program regression suite passed. Publication describes source and recorded fleet evidence accurately; it does not imply that every installation automatically runs the newest source or that every skin has received a fresh visual sweep.